

Risk Scoring Report — vulnerable-invoice-service

Project: com.demo.supplychain:vulnerable-invoice-service:1.0.0 · **Generated:** 2026-06-11 · **Source SHA:** 61ed8c3140d76e3a19a88954e834d39c9f7635fb · **Scanner:** OWASP Dependency-Check 11.0.0 · **Model:** 0.5·CVE_severity + 0.3·exposure + 0.2·business_criticality

Executive Summary

Metric	Value
Dependencies scanned	15
Dependencies with CVEs	9
Total CVEs detected	80
CRITICAL-severity CVEs	16
HIGH-severity CVEs	50
MEDIUM-severity CVEs	13
LOW-severity CVEs	1
Risk bands (deps)	0 CRITICAL · 6 HIGH · 3 MEDIUM · 0 LOW

Risk bands: **CRITICAL** ≥ 8.0 · **HIGH** 6.0–7.9 (or has CRITICAL CVE) · **MEDIUM** 3.0–5.9 · **LOW** < 3.0

Supply-Chain Findings (Non-CVE)

Type	Detail	Severity
Typosquatted dependency	com.fastxml.jackson.core:jackson-databind:2.9.8 — groupId missing "er", impersonates com.fasterxml	CRITICAL
Insecure repository	http://insecure-mirror.example.net/maven2 — plain HTTP, susceptible to MITM/dependency substitution	HIGH
License policy violation	mysql:mysql-connector-java:8.0.30 — GPL-2.0 in a permissive-only project	MEDIUM

Ranked Remediation Backlog

#	Coordinate	Risk	Band	CVE Sev	Exposure	Criticality	Top CVE	Fix Version
1	org.apache.logging.log4j:log4j-core:2.14.1	7.8	HIGH	10.0	8.0	2.0	CVE-2021-44228 (10.0)	2.17.2
2	com.fasterxml.jackson.core:jackson-databind:2.9.8	7.8	HIGH	10.0	8.0	2.0	CVE-2019-14379 (9.8)	2.13.5
3	org.apache.logging.log4j:log4j-api:2.14.1	7.6	HIGH	9.5	8.0	2.0	CVE-2026-34479 (7.5)	2.17.2

4	mysql:mysql-connector-java:8.0.30	7.0	HIGH	8.3	8.0	2.0	CVE-2023-22102 (8.3)	8.0.33
5	com.google.protobuf:protobuf-java:3.19.4	7.0	HIGH	9.5	6.0	2.0	CVE-2022-3171 (7.5)	3.21.7
6	com.google.guava:guava:24.1.1-jre	6.3	HIGH	7.6	7.0	2.0	CVE-2023-2976 (7.1)	32.0.0-jre
7	com.fasterxml.jackson.core:jackson-annotations:2.9.0	5.5	MEDIUM	6.5	6.0	2.0	CVE-2018-1000873 (6.5)	2.13.5 (transitive)
8	commons-io:commons-io:2.4	5.2	MEDIUM	5.3	7.0	2.0	CVE-2021-29425 (4.8)	2.14.0
9	org.apache.commons:commons-lang3:3.4	5.2	MEDIUM	5.3	7.0	2.0	CVE-2025-48924 (5.3)	3.14.0

Detailed Findings

Rank 1 — HIGH 7.8 — org.apache.logging.log4j:log4j-core:2.14.1

CVEs (9 total): CVE-2021-44228 CVSS 10.0 (Log4Shell — remote code execution via JNDI lookup), CVE-2021-45046 CVSS 9.0, CVE-2026-34479/80/81 CVSS 7.5, plus 4 more.

Fix: Upgrade to 2.17.2 (minimum safe version addressing Log4Shell). Latest stable: 2.23.1.

Rationale: Direct compile dependency actively used in DiscountCalculator.java. Log4Shell (CVE-2021-44228) allows unauthenticated remote code execution. CRITICAL CVE floor enforces HIGH band minimum. Density bonus (9 CVEs) caps CVE severity score at 10.0.

Rank 2 — HIGH 7.8 — com.fasterxml.jackson.core:jackson-databind:2.9.8

CVEs (54 total): 14 × CVSS 9.8 CRITICAL deserialization CVEs (CVE-2019-14379, CVE-2019-14540, CVE-2019-14892, CVE-2019-14893, CVE-2019-16335, CVE-2019-16942, CVE-2019-16943, CVE-2019-17267, CVE-2019-17531, CVE-2019-20330, CVE-2020-8840, CVE-2020-9546, CVE-2020-9547, CVE-2020-9548), 33 × HIGH, 3 × MEDIUM.

Fix: Upgrade to 2.13.5 or 2.15.4+ (latest 2.17.x).

Rationale: Direct compile dep. Deserialization library with the largest CVE surface in this project (54 CVEs). Density bonus saturates the 10.0 cap. CRITICAL CVE floor enforces HIGH band minimum.

Rank 3 — HIGH 7.6 — org.apache.logging.log4j:log4j-api:2.14.1

CVEs (5 total): CVE-2026-34479/80/81 CVSS 7.5 (HIGH), CVE-2026-34477 CVSS 5.9, CVE-2025-68161 CVSS 4.8. Max CVSS 7.5; density bonus (+2.0) → capped at 9.5.

Fix: Upgrade to 2.17.2 (same release train as log4j-core — upgrade together).

Rank 4 — HIGH 7.0 — mysql:mysql-connector-java:8.0.30

CVEs (1 total): CVE-2023-22102 CVSS 8.3 (HIGH) — MITM attack allows remote code execution on the client.

Fix: Upgrade to 8.0.33. Also evaluate migrating to com.mysql:mysql-connector-j. GPL-2.0 license policy violation requires legal review.

Rank 5 — HIGH 7.0 — com.google.protobuf:protobuf-java:3.19.4

CVEs (5 total): CVE-2022-3171/3509/3510 CVSS 7.5 (DoS via crafted proto messages), CVE-2024-7254 CVSS 7.5, CVE-2026-0994 CVSS 7.5.

Fix: Upgrade to `3.21.7` +. Resolved automatically when `mysql-connector-java` is upgraded to 8.0.33.

Rank 6 — **HIGH** 6.3 — `com.google.guava:guava:24.1.1-jre`

CVEs (2 total): CVE-2023-2976 CVSS 7.1 (insecure temp dir creation, local privilege escalation), CVE-2020-8908 CVSS 3.3 (LOW). Density bonus: +0.5 → 7.6.

Fix: Upgrade to `32.0.0-jre` (addresses all CVEs; latest `33.6.0-jre`).

Rank 7–9 — **MEDIUM** — Commons / Jackson Annotations

- `jackson-annotations:2.9.0` (5.5): CVE-2018-1000873. Resolved transitively by upgrading `jackson-databind`.
- `commons-io:2.4` (5.2): CVE-2021-29425 (path traversal), CVE-2024-47554. Fix: `2.14.0`.
- `commons-lang3:3.4` (5.2): CVE-2025-48924. Fix: `3.14.0`.

Priority Recommendations

1. **P0 — Remove typosquatted dependency** — `com.fastxml.jackson.core:jackson-databind:2.9.8` must be deleted from `pom.xml` immediately (supply-chain attack vector).
2. **P0 — Upgrade log4j-core + log4j-api to 2.17.2** — Log4Shell actively exploited in the wild; patch within 24 hours.
3. **P1 — Upgrade jackson-databind to 2.13.5+** — 14 CRITICAL deserialization CVEs; broadest attack surface.
4. **P1 — Remove insecure HTTP Maven mirror** — delete `internal-untrusted-mirror` repository or switch to HTTPS.
5. **P2 — Upgrade mysql-connector-java to 8.0.33 + legal review of GPL-2.0.**
6. **P2 — Upgrade guava to 32.0.0-jre.**
7. **P3 — Routine bumps** — `commons-io 2.14.0`, `commons-lang3 3.14.0`.

Machine-readable source: `depscan-risk-report.json`. `depscan-risk-report.json` is ready for the **Auto-Remediation Skill** (Stage 3) and the **PR Validation Agent** (Stage 4).